

Think Beyond Practice LLC

HIPAA BUSINESS ASSOCIATE AGREEMENT

THIS BUSINESS ASSOCIATE AGREEMENT (hereinafter "Agreement"), between _____, Inc. (hereinafter "Covered Entity") and Think Beyond Practice LLC (hereinafter "Business Associate"), effective as of the date last signed by the parties below (the "Effective Date"), complies with the Health Insurance Portability and Accountability Act of 1996 ("HIPAA"), Public Law 104-191, the Health Information Technology for Economic and Clinical Health Act (the "HITECH Act"), Public Law 111-005, and the regulations promulgated thereunder; 45 C.F.R. Parts 160, 162 and 164, to include the "Privacy Rule," the "Security Rule" and the "Breach Notification Rule" (collectively, the "**Privacy, Security & Notification Rules**").

The Washington Uniform Health Care Information Act (Chapter 70.02 RCW) Addendum attached hereto as **Exhibit A** ("Washington Addendum") is hereby incorporated into and made part of this Agreement as though fully set forth herein. Business Associate shall comply with all obligations set forth in the Washington Addendum. In the event of any conflict between this Agreement and the Washington Addendum, the more stringent and protective requirement shall control.

Covered Entity and Business Associate may be referred to herein individually as "Party" or collectively as "Parties."

BACKGROUND

Covered Entity acknowledges that it is subject to the Privacy, Security & Notification Rules.

Business Associate provides or will provide services to Covered Entity pursuant to one or more agreements, hereinafter referred to as "Service Agreement(s)."

In the course of executing Service Agreement(s), Business Associate may come into contact with, use, or disclose Protected Health Information ("PHI") (defined in Section 1 below). Each Service Agreement, and any future agreement between the Parties which constitute a Service Agreement, is hereby incorporated by reference and shall be taken and considered as a part of this document the same as if fully set out herein, whether or not the Service Agreement(s) expressly references such incorporation.

In accordance with the Privacy, Security & Notification Rules, which require Covered Entity to have a written contract with each of its Business Associates, the Parties wish to establish satisfactory assurances that Business Associate will appropriately safeguard PHI and, therefore, make this Agreement.

1. DEFINITIONS

- 1.1. Terms used, but not otherwise defined, in this Agreement shall have the same meaning as those terms are defined in HIPAA.
- 1.2. "Artificial Intelligence" or "AI" refers to a machine-based system that given certain objectives, interacts with data to generate predictions, recommendations, or other outputs, including but not limited to large and small language, machine learning and deep learning models.
- 1.3. "Breach" shall have the meaning set out in 45 C.F.R. § 164.402.
- 1.4. "Designated Record Set" shall have the meaning set out in 45 C.F.R. § 164.501.
- 1.5. "Health Care Operations" shall have the meaning set out in 45 C.F.R. § 164.501.

- 1.6. "HIPAA" refers to the Health Insurance Portability and Accountability Act of 1996, Public Law 104-191, the Health Information Technology for Economic and Clinical Health Act (the "HITECH Act"), Public Law 111-005, and the regulations promulgated thereunder; 45 C.F.R. Parts 160, 162 and 164 (as well as any amendments thereto).
- 1.7. "Individual" shall have the same meaning as the term "individual" set out in 45 CFR § 160.103 and shall include a person who qualifies as a personal representative in accordance with 45 CFR § 164.502(g).
- 1.8. "Covered Entity Data" means (i) all data and information stored or caused to be stored on or within the Business Associate's Platform (to include PHI); (ii) all data and information processed by Business Associate (to include PHI); and (iii) the transformations, modifications, adaptations, customizations, correlations, hashes, vectors, data mining, matrices, tables, translations, extractions, algorithms, models, improvements, results, outputs, reports or derivatives generated or computed in whole or part from or to the foregoing (i) and (ii).
- 1.9. "Platform" means the Think Beyond Practice software platform, comprised of three Modules: the Practice Hub, the Credentialing Hub, and the Community and Education Hub (to include all of the tools and features within each Hub), and any other current or future Platform features. The Parties acknowledge that neither the Credentialing Hub nor the Community and Education Hub process PHI - although they may process non-PHI, Personal Information (e.g., Credentialing Hub may process provider credentialing information (such as NPI numbers)) – and are included in this definition solely for purposes of completeness.
- 1.10. "Process" or "Processing" shall mean operation or a set of operations performed upon PHI, to include collection, creating, accessing, viewing, use, disclosure, structuring, adaptation, alteration, manipulation, retrieval, transmission, transfer, sharing, storage, retention, logging, generation, transformation, destruction or disposal of such information.
- 1.11. "Protected Health Information" or "PHI" – which includes but is not limited to Protected Health Information in electronic form (i.e., ePHI) - shall have the same meaning as the term "protected health information" in 45 CFR § 160.103, and refers to information Processed by Business Associate from or on behalf of Covered Entity, to include through the Platform.
- 1.12. "Required by Law" shall have the meaning as set out in 45 CFR § 164.103.
- 1.13. "Secretary" means the Secretary of the United States Department of Health and Human Services or their designee.
- 1.14. "Security Incident" has the meaning set out in 45 C.F.R. § 164.304.
- 1.15. "Subcontractor" has the meaning set out in 45 C.F.R. § 160.103.
- 1.16. "Unsuccessful Security Incident" means an incident such as a "ping" or other unsuccessful attempt to access a network, an unsuccessful login attempt, network probe, port scan, or similar event that, individually and in the aggregate, does not result in actual compromise of the system, or PHI.
- 1.17. "Workforce Member(s)" shall have the meaning of "Workforce" set out in 45 CFR § 160.103.

2. REQUIREMENTS AND OBLIGATIONS OF BUSINESS ASSOCIATE

- 2.1. Business Associate agrees to fully comply with the requirements under the Privacy, Security & Notification Rules applicable to "Business Associates" and not use or further disclose PHI other than as permitted or required by this Agreement, Service Agreement(s), or as Required by Law. In case of any conflict between this Agreement and Service Agreement(s), this Agreement shall govern.

Business Associate acknowledges that certain information received from Covered Entity constitutes "Health Care Information" subject to Chapter 70.02 RCW. Business Associate shall not use or disclose such information in any manner that would violate Chapter 70.02 RCW if such use or disclosure were made by Covered Entity.

Business Associate shall comply with the Washington Addendum, and shall cause each Subcontractor, agent and affiliate that receives Health Care Information to agree in writing to comply with obligations no less protective than those imposed by this Agreement and the Washington Addendum.

In the event of any inconsistency between HIPAA and applicable Washington law, Business Associate shall comply with the requirement that affords greater protection to the individual whose information is at issue.

2.2. Training

- 2.2.1. Business Associate agrees to implement a security awareness and training program for all Workforce Members that will have access to PHI.

- 2.2.2. Business Associate agrees to train all Workforce Members on the policies and procedures with respect to properly handling and safeguarding PHI, as necessary and appropriate to carry out their functions, and that such training shall comply with the requirements of 45 CFR §164.530(b). Such training shall:

2.2.2.1. Include awareness training regarding the privacy and security of PHI, including the principle of Role Based Access, and application of the minimum necessary principles;

2.2.2.2. Include periodic reminders about the need to make good faith efforts to maintain the privacy and security of PHI;

2.2.2.3. Be provided as follows:

2.2.2.3.1. To each Workforce Member, as necessary and appropriate;

2.2.2.3.2. To each new Workforce Member within a reasonable period of time after the person is to be given access to PHI; and

2.2.2.3.3. To each Workforce Member whose job functions are affected by a material change in Business Associate's policies or procedures or a material change in the Privacy, Security & Notification Rules, with such training to occur within a reasonable period of time after the material change becomes effective.

- 2.2.3. Business Associate shall document and retain records of training for each of its Workforce Members, to include the date the Workforce Member was first given access to Covered Entity's PHI, the date of the training, the title of the training, and the subject matter of the training (i.e., HIPAA Privacy Rule, HIPAA Security Rule, HIPAA Notification Rule). Business

Associate will retain such records for at least six (6) years from the date such training was completed, or the date when such record was created, whichever is later.

2.2.4. Upon request from Covered Entity, Business Associate shall provide a certification attesting that it has complied with the above training requirements.

- 2.3. Business Associate agrees to use appropriate procedural, physical, and electronic safeguards to prevent use or disclosure of PHI other than as provided for by this Agreement. Said safeguards shall include, but are not limited to, requiring employees to agree to use or disclose PHI only as permitted or required by this Agreement and taking related disciplinary actions for inappropriate use or disclosure, as necessary.
- 2.4. Business Associate shall require its Subcontractors, agents and affiliates to whom it provides PHI received from, created or received by, Business Associate on behalf of Covered Entity or that carries out any duties for the Business Associate involving the Processing of PHI, to agree, by written contract with Business Associate, to the same restrictions and conditions that apply through this Agreement to Business Associate with respect to such information, in accordance with 45 C.F.R. § 164.502(e)(1)(ii). Business Associate shall maintain Business Associate Agreements with all such Subcontractors, agents and affiliates. A current list of Subcontractors, agents and affiliates that may process PHI is available at <https://thinkbeyondpractice.com/subprocessors>.
- 2.5. Business Associate acknowledges that there may be contractual, legal or regulatory requirements that restrict the location where Covered Entity's PHI can be processed (i.e., restrictions on processing such data outside of the United States). As such, Business Associate agrees to process all of Covered Entity's PHI solely within the United States, unless Business Associate has secured express written consent from Covered Entity to process said information in a different location. Business Associate further acknowledges that this restriction on the location of processing applies not only to Business Associate's Workforce Members, but also to anyone who may have access to PHI through Business Associate, to include, its Subcontractors, agents, affiliates, and service providers.
- 2.6. **Notification and Reporting.** Business Associate agrees to:
- 2.6.1. Report to Covered Entity any use or disclosure of PHI not provided for by this Agreement, or in violation of this Agreement, including any Security Incident or Breach of unsecured PHI, except that the Parties acknowledge and agree that this Section constitutes notice to Covered Entity of the regular occurrence of Unsuccessful Security Incidents, for which no further notification is required.
- 2.6.2. Mitigate, to the extent practicable, any harmful effect that is known to Business Associate of a use or disclosure of PHI by Business Associate, in violation of the requirements of this Agreement.
- 2.6.3. Notify Covered Entity immediately following the "discovery" (within the meaning of 45 C.F.R. §164.410(a)) of an unauthorized use or disclosure of PHI. Initial notification of such event does not need to be in compliance with 45 C.F.R. §164.404(c); however, Business Associate must provide Covered Entity with all information necessary for Covered Entity to comply with 45 C.F.R. §164.404(c) and 45 C.F.R. §164.410(c) without unreasonable delay, and in no case later than ten (10) business days following the discovery of such unauthorized use or disclosure. Business Associate shall be liable for the costs associated with a Breach of unsecured PHI if such Breach is caused by Business Associate's acts or omissions, or the acts or omissions of Business Associate's affiliates, officers, directors, employees, agents, or Subcontractors.

- 2.6.4. Cooperate in good faith with Covered Entity in any investigation of a Breach and in any notification Covered Entity may be required to make to Individuals, the Secretary, or the media under 45 C.F.R. §§ 164.404, 164.406, and 164.408.
- 2.6.5. Content of Notification. The notification provided under this section shall include, to the extent possible: (a) The identification of each Individual whose Unsecured PHI has been, or is reasonably believed by Business Associate to have been, accessed, acquired, used, or disclosed during the Breach; (b) A description of what happened, including the date of the Breach and the date of discovery; (c) A description of the types of Unsecured PHI involved; (d) A description of any steps Individuals should take to protect themselves from potential harm resulting from the Breach; (e) A description of what Business Associate is doing to investigate the Breach, mitigate harm, and prevent further Breaches; (f) Contact information for Individuals to ask questions or learn additional information.
- 2.6.6. Costs. Reasonable costs of Breach notification, mitigation, and remediation shall be allocated as follows: each Party shall bear the costs attributable to its own actions or omissions giving rise to the Breach. Where the Breach results from a failure of Business Associate's safeguards or those of Business Associate's affiliates, officers, directors, employees, agents, or Subcontractors, Business Associate shall bear the reasonable costs of Breach notification and mitigation, subject to the limitations of liability set forth in the Service Agreement(s).
- 2.7. The Parties acknowledge that the Platform is not designed to maintain a Designated Record Set on behalf of Covered Entity. PHI processed through the Platform is delivered to Covered Entity, who is responsible for maintaining the Designated Record Set within Covered Entity's own records system.
- 2.7.1. To the extent Business Associate retains PHI in a form that constitutes part of a Designated Record Set, then Business Associate agrees to:
- 2.7.1.1. provide access to Covered Entity or, as directed by Covered Entity, to an Individual, in order to meet the requirements under 45 CFR § 164.524, provided that Business Associate shall have at least ten (10) days from Covered Entity's notice to provide access to, or deliver such information.
- 2.7.1.2. make any amendments to such information, at the request of Covered Entity or an Individual, in accordance with 45 C.F.R. § 164.526, in the time and manner designated by Covered Entity, provided that Business Associate shall have at least ten (10) days from Covered Entity's notice to make an amendment.
- 2.8. Business Associate agrees to make its internal practices, books, and records including policies and procedures for processing PHI, received from, created by or received by Business Associate on behalf of, Covered Entity, available to Covered Entity or to the Secretary, in a time and manner designated by the Covered Entity or the Secretary, for purposes of determining Covered Entity's or Business Associate's compliance with the Privacy, Security and Notification Rules.
- 2.9. Business Associate agrees to document disclosures of PHI and information related to such disclosures as would be required for Covered Entity to respond to a request by an Individual for an accounting of disclosure of PHI in accordance with 45 CFR § 164.528. Business Associate further agrees to retain a record of each disclosure for a period of time of no less than six (6) years from the date of such disclosure, so that Covered Entity is able to meet its obligations under 45 CFR § 164.528.
- 2.10. Business Associate agrees to provide Covered Entity, or an Individual, in a time and manner designated by Covered Entity, information to respond to a request by an Individual for an

accounting of disclosures of PHI in accordance with 45 CFR § 164.528, provided that, unless a shorter time is required by law, Business Associate shall have at least fifteen (15) business days from Covered Entity's notice to provide access to, or deliver such information which shall include, at minimum, (a) date of the disclosure; (b) name of the third party to whom the PHI was disclosed and, if known, the address of the third party; (c) brief description of the disclosed information; and (d) brief explanation of the purpose and basis for such disclosure.

2.11. Business Associate agrees it must limit any use, disclosure, or request for use or disclosure of PHI to the minimum amount necessary to accomplish the intended purpose of the use, disclosure, or request in accordance with the requirements of the Privacy Rule.

2.11.1. Business Associate represents to Covered Entity that all its uses and disclosures of, or requests for, PHI shall be the minimum necessary in accordance with the Privacy Rule.

2.11.2. Covered Entity may, pursuant to the Privacy Rule, reasonably rely on any requested disclosure as the minimum necessary for the stated purpose when the information is requested by Business Associate.

2.12. Business Associate agrees to adequately and properly maintain all PHI received from, or created or received on behalf of, Covered Entity, document subsequent uses and disclosures of such information by Business Associate as may be deemed necessary and appropriate by the Covered Entity, and provide Covered Entity with reasonable access to examine and copy such records and documents during normal business hours of Business Associate.

2.13. Business Associate agrees that Covered Entity may at any time review Business Associate's privacy and/or security policies and procedures to determine whether they are consistent with Covered Entity's policies, procedures, and practices, and shall promptly notify Business Associate in writing regarding any modifications Covered Entity may reasonably believe are needed in order to meet Covered Entities requirements.

2.14. Business Associate agrees that Covered Entity may at any time review the training materials used by Business Associate to comply with Section 2.2 (Training), as well as all records and documentation relating to the provision of such training, and shall promptly notify Business Associate in writing regarding any issues identified, as well as recommended modifications Covered Entity may reasonably believe needed for Business Associate to meet its requirements.

2.15. If Business Associate receives a request from an Individual for a copy of the Individual's PHI, and such information is in the sole possession of the Business Associate, Business Associate will provide the requested copies to the Individual and notify the Covered Entity of such action. If Business Associate receives a request for Protected Health Information in the possession of the Covered Entity, or receives a request to exercise other individual rights as set forth in the Privacy Rule, Business Associate shall notify Covered Entity of such request and forward the request to Covered Entity. Business Associate shall then assist Covered Entity in responding to the request.

2.16. Security Measures.

2.16.1. **Safeguards:** HIPAA, as well as the Privacy, Security and Notification Rules, require that the administrative, physical and technical safeguards, as well as the policies, procedures and documentation requirements that apply to Covered Entity, shall apply in the same manner to Business Associate. Pursuant to the foregoing requirements, Business Associate will implement administrative, physical, and technical safeguards that reasonably and appropriately protect the confidentiality, integrity, and availability of the PHI that it Processes. Business Associate will also ensure that any Subcontractors, agents or affiliates to whom it provides such information, agrees to implement similar reasonable and appropriate

safeguards to protect such information. Business Associate's safeguards include, without limitation:

- 2.16.1.1. Encryption of PHI in transit and at rest, where applicable;
 - 2.16.1.2. Access controls limiting Workforce Members and Subcontractor, agents and affiliates' access to PHI on a least-privilege basis;
 - 2.16.1.3. Audit logging of administrative access to systems that process PHI;
 - 2.16.1.4. Authentication controls including support for multi-factor authentication;
 - 2.16.1.5. Data minimization practices including limited retention of PHI processed through the Platform, in accordance with the Platform's data flow design;
 - 2.16.1.6. Vendor management procedures for Subcontractors;
 - 2.16.1.7. Workforce Member training on HIPAA obligations;
 - 2.16.1.8. Incident response and breach notification procedures.
 - 2.16.1.9. PHI contained in portable devices or removable media shall be encrypted.
- 2.16.2. Business Associate shall, at its own cost and effort, monitor the issuance of laws, regulations, and guidance, including but not limited to guidance related to HIPAA or provided by the U.S. Department of Health and Human Services, on the most effective and appropriate safeguards for use in carrying out the requirements set out in this Agreement, and the Privacy, Security & Notification Rules.
- 2.17. Business Associate agrees to fully cooperate in good faith with and to assist Covered Entity in complying with the requirements of the Privacy, Security & Notification Rules.

3. PERMITTED/PROHIBITED USES AND DISCLOSURES BY BUSINESS ASSOCIATE

3.1. Business Associate acknowledges and agrees:

- 3.1.1. limit its use, disclosure, and request of PHI to the minimum necessary to accomplish the intended purpose, in accordance with 45 C.F.R. §§ 164.502(b) and 164.514(d).
- 3.1.2. that the obligations under HIPAA's Privacy, Security & Notification Rules, including but not limited to accounting for certain PHI disclosures for treatment, restrictions on the sale of PHI, restrictions on marketing and fundraising communications, payment and health care operations, that apply to the Covered Entity, shall apply equally to Business Associate. Business Associate further agrees that it shall not use even aggregated and/or de-identified PHI received from Covered Entity for any type of marketing purposes.
- 3.1.3. to not: (a) use or disclose PHI in a manner that would violate HIPAA, or the Privacy, Security or Notification Rules, if done by Covered Entity, except as expressly permitted under 45 C.F.R. §§ 164.504(e)(2)(i)(A) or (B); and (b) use or disclose PHI for marketing purposes or to sell PHI, except as permitted under HIPAA, and only with Covered Entity's written authorization.

- 3.1.4. that it is prohibited from using any PHI or Covered Entity Data that it has access to, for the purposes of any processing by any AI solutions or models, without the prior written permission of Covered Entity. Business Associate further acknowledges that this prohibition extends to any use by Business Associate of PHI or Covered Entity Data to: i) train its algorithms or models, or to otherwise create transformations, correlations, hashes, vectors, data mining, matrices, tables, classifiers, translations, extractions, algorithms, derivatives or models; and ii) create, develop train, or fine-tune AI, including developing or training generative or non-generative models, algorithms, or engineered or machine learning systems, unless specified and approved by Covered Entity in writing. This restriction does not prohibit Business Associate from using de-identified data, aggregated data, synthetic data, or other data that does not constitute PHI for AI development purposes
- 3.2. Covered Entity retains all rights, title, interest, ownership, and intellectual property rights in Covered Entity Data, including but not limited to any vectors, hash indices, files or tables, or any algorithms, models or other derivatives generated in whole or part from or containing any Covered Entity Data.
- 3.3. Business Associate agrees that it will not deidentify or aggregate PHI for the purposes of processing or using AI solutions, without the prior written permission of Covered Entity. Any PHI that has been deidentified or aggregated following Covered Entity's written permission will not be used for any purpose other than to provide the products and services to Covered Entity and for the sole and exclusive benefit of Covered Entity. As between Covered Entity and Business Associate, Business Associate shall make no claims of rights, title, interest, ownership, or intellectual property rights in any PHI that is deidentified or aggregated.
- 3.4. Except as otherwise limited in this Agreement, Business Associate may use or disclose PHI to perform functions, activities, or services for, or on behalf of, Covered Entity as specified in Service Agreement(s), provided that such use or disclosure would not violate the Privacy Rule if done by Covered Entity.
- 3.5. Except as otherwise limited in this Agreement, Business Associate may use PHI as required for Business Associate's proper management and administration or to carry out the legal responsibilities of the Business Associate.
- 3.6. Except as otherwise limited in this Agreement, Business Associate may disclose PHI for the proper management and administration of the Business Associate, provided that disclosures are Required by Law, or provided that, if Business Associate discloses any PHI to a third party for such a purpose, Business Associate shall enter into a written agreement with such third party requiring the third party to: (a) maintain the confidentiality of such PHI and not to use or further disclose such information except as Required by Law or for the purpose for which it was disclosed, and (b) notify Business Associate of any instances in which it becomes aware in which the confidentiality of the PHI is Breached.
- 3.7. Except as otherwise limited in this Agreement, Business Associate may use PHI to provide data aggregation services relating to the health care operations of Covered Entity, as permitted by 42 CFR § 164.504(e)(2)(i)(B).

4. OBLIGATIONS OF COVERED ENTITY

- 4.1. Covered Entity has publicly posted its Notice of Privacy Practices ("Notice") on its website, in accordance with HIPAA. Business Associate acknowledges that it is responsible for reviewing that Notice and abiding by all commitments in such Notice, to include all permitted, prohibited and

required uses or disclosures of PHI, as well as any revisions to said Notice that may be made from time to time (identified through the effective date set out in the Notice).

- 4.2. Covered Entity shall provide Business Associate with any changes in, or revocation of, permission by an Individual to use or disclose PHI, if such changes affect Business Associate's permitted or required uses or disclosures.
- 4.3. Covered Entity shall notify Business Associate of any restriction to the use or disclosure of PHI that Covered Entity has agreed to in accordance with 45 CFR § 164.522, to the extent that such restriction may affect Business Associate's use or disclosure of PHI.
- 4.4. Covered Entity shall retain responsibility for securing the consent of their patients to the collection and Processing of their PHI in accordance with this Agreement. To the extent that Covered Entity provides Business Associate with the cellular/mobile phone number/email of a patient, Covered Entity will have secured the patient's consent for Business Associate to contact that patient (on behalf of Covered Entity) for purposes of treatment, payment and healthcare operations.

5. PERMISSIBLE REQUESTS BY COVERED ENTITY

- 5.1. Covered Entity shall not request Business Associate to use or disclose PHI in any manner that would not be permissible under the Privacy Rule if done by Covered Entity.

6. PLATFORM-SPECIFIC REQUIREMENTS

- 6.1. Email and Messaging Channels. The Parties acknowledge that certain Platform features may transmit PHI to Covered Entity through email or other messaging channels (e.g., delivery of patient assessment results, letter generator outputs, or notifications). Business Associate maintains Business Associate Agreements with its print and mail service provider, as well as with the email and messaging service providers through which digital transmissions are routed, and applies appropriate administrative, physical and technical safeguards to such transmissions. Business Associate's safeguards do not extend to email systems or environments outside of Business Associate's (or its Subcontractors, agents and affiliates) control. Covered Entity acknowledges and agrees that Covered Entity is responsible for the security of Covered Entity's own email/messaging environment(s), including the email address and account through which Covered Entity receives communications.
- 6.2. Appropriate Use of Platform. Covered Entity shall: (a) Use the Platform in accordance with the Platform Service Agreement (and any supporting documentation provided by Business Associate); (b) Submit PHI only through Platform features designed to handle PHI; (c) Obtain consents, authorizations, and/or provide notices required by HIPAA, state law, or applicable professional standards, relating to such information; (d) Maintain the security of its account credentials and notify Business Associate promptly of any suspected compromise; (e) Comply with Covered Entity's own HIPAA obligations when using the Platform.

7. TERM AND TERMINATION

- 7.1. Term. This Agreement, effective as of the Effective Date, shall terminate when all of the PHI provided by Covered Entity to Business Associate, or created or received by Business Associate on behalf of Covered Entity, is destroyed or returned to Covered Entity, unless it is infeasible to return or destroy PHI, in which case Section 7.3, below, shall apply.

7.2. Termination for Cause.

7.2.1. This Agreement authorizes and Business Associate acknowledges and agrees that Covered Entity shall have the right to immediately terminate this Agreement and any Service Agreement(s) in the event Business Associate fails to comply with, or violates a material provision of this Agreement, or any requirements of the Privacy, Security & Notification Rules.

7.2.2. Upon Covered Entity's knowledge of a material breach by Business Associate,

7.2.2.1. Covered Entity shall, whenever practicable, provide a reasonable opportunity for Business Associate to cure the breach or end the violation.

7.2.2.2. If cure is not possible or if Business Associate does not cure a curable breach or end the violation within a reasonable time as specified by, and at the sole discretion of, Covered Entity, Covered Entity may immediately terminate this Agreement and Service Agreement(s).

7.2.3. Upon Business Associate's knowledge of a material breach of this Agreement by Covered Entity, Business Associate shall have the same right to provide notice, cure period, and termination.

7.3. Effect of Termination.

7.3.1. Except as provided in Section 7.3.2. below, upon termination of this Agreement for any reason, Business Associate shall return or destroy all PHI received from Covered Entity or created or received by Business Associate on behalf of Covered Entity. This provision shall also apply to PHI that is in the possession of Subcontractors, agents or affiliates of Business Associate. Business Associate shall retain no copies of the PHI.

7.3.2. In the event that Business Associate determines that returning or destroying the PHI is not feasible, Business Associate shall provide to Covered Entity notification of the conditions that make return or destruction infeasible. Upon mutual agreement of the Parties that return, or destruction of PHI, is infeasible, Business Associate shall extend the protections of this Agreement to such information and limit further uses and disclosures of such information to those purposes that make the return or destruction infeasible, for so long as Business Associate maintains such information.

7.3.3. To the extent that a particular tool within the Platform processes PHI transiently, the Parties acknowledge that such PHI is not retained for ongoing storage beyond what is necessary to deliver the requested outputs to Covered Entity, and that at the time of termination little or no such PHI may remain in operational systems subject to return or destruction. To the extent other tools store PHI persistently, the return or destruction obligations set forth above apply. Patient information may persist transiently in encrypted backups during normal backup rotation, after which it is destroyed.

8. MISCELLANEOUS

8.1. Indemnification. To the extent permitted by law, each Party (the "Indemnifying Party") agrees to indemnify and hold harmless the other Party, and its affiliates, officers, directors, employees, agents, and Subcontractors from and against all actual and direct losses (including, without limitation, reasonable attorney's fees, defense costs, and equitable relief) arising out of, resulting from, or attributable to any acts or omissions or other conduct of the Indemnifying Party, or its affiliates, officers, directors, employees, agents, or Subcontractors, in connection with the

performance of duties under this Agreement. This indemnity shall not be construed to limit either Party's rights, if any, to common law indemnity.

- 8.2. Insurance Coverage. Business Associate shall maintain sufficient insurance coverage as shall be necessary to insure Business Associate, its Subcontractors, agents and affiliates, for damages incurred, including but not limited to any costs and expenses associated with notification under the Breach Notification Rule and/or state law, by Covered Entity and/or other third parties as a result of Business Associate's unauthorized use or disclosure of PHI, Breach of unsecured PHI, or a Security Incident.
- 8.3. Regulatory Reference. A reference in this Agreement to a section in the HIPAA Privacy, Security & Notification Rules means the section as in effect or as amended.
- 8.4. Amendment. The Parties agree to amend this Agreement from time to time as is necessary for Covered Entity to comply with the requirements of HIPAA, the Privacy, Security & Notification Rules, and any amendments thereto, as well as any related regulations, upon the effective date of such amendment, regardless of whether this Agreement has been formally amended.
- 8.5. Survival. The respective rights and obligations of the Parties under this Agreement shall survive the termination of this Agreement.
- 8.6. Interpretation. Any ambiguity in this Agreement shall be resolved in favor of a meaning that permits compliance with the Privacy, Security & Notification Rules.
- 8.7. No Third-Party Beneficiaries. Nothing in this Agreement shall be construed to create any rights or remedies in any third party, including any Individual, except as expressly required by HIPAA.
- 8.8. Notices and Communications. All instructions, notices, consents, demands, or other communications required or contemplated by this Agreement shall be in writing and shall be delivered by hand, by facsimile transmission, by email, by overnight courier service, or by prepaid first class registered or certified mail (return receipt requested), addressed to the respective Party at the appropriate facsimile number, email or address as set forth below, or to such other Party, facsimile number, email or address as may be hereafter specified by written notice.

COVERED ENTITY

Name
Attn:
Title:
Address:
Telephone:
Fax:
Email

With copy to: _____

BUSINESS ASSOCIATE

Name:
Attn:
Title:
Address:
Telephone:
Fax:
Email

All instructions, notices, consents, demands, or other communications shall be considered effectively given as of the date of hand delivery; upon delivery confirmation if sent by overnight courier service or by prepaid first class registered or certified mail; or upon the date of transmission (or the next business day, if it is not a business day), if sent by facsimile or email.

- 8.9. Strict Compliance. No failure by any Party to insist upon strict compliance with any term or provision of this Agreement, to exercise any option, to enforce any right, or to seek any remedy upon any default of any other Party shall affect, or constitute a waiver of, any Party's right to insist upon such strict compliance, exercise that option, enforce that right, or seek that remedy with respect to that default or any prior, contemporaneous, or subsequent default. No custom or practice of the Parties at variance with any provision of this Agreement shall affect, or constitute a waiver of, any Party's right to demand strict compliance with all provisions of this Agreement.
- 8.10. Severability. With respect to any provision of this Agreement finally determined by a court of competent jurisdiction to be unenforceable, such court shall have jurisdiction to reform such provision so that it is enforceable to the maximum extent permitted by applicable law, and the Parties shall abide by such court's determination. In the event that any provision of this Agreement cannot be reformed, such provision shall be deemed to be severed from this Agreement, but every other provision of this Agreement shall remain in full force and effect.
- 8.11. Governing Law. This Agreement shall be governed by and construed in accordance with the laws of the State of Washington.
- 8.12. Compensation. There shall be no remuneration for performance under this HIPAA Business Associate Agreement except as specifically provided by, in, and through, the Service Agreement(s) referenced herein.
- 8.13. Recitals. This Agreement's preliminary recitals are incorporated herein by reference as though fully set forth at length herein.
- 8.14. Counterparts and Electronic Acceptance. This Agreement may be accepted electronically, and electronic acceptance shall have the same force and effect as a signed original.

Signature Page(s) to Follow

IN WITNESS WHEREOF, the Parties hereto have executed this Agreement through their duly authorized representatives.

COVERED ENTITY

(Entity Name)

(Signature)

Name: _____

Title: _____

Date: _____

BUSINESS ASSOCIATE

(Business Associate Name)

(Signature)

Name: _____

Title: _____

Date: _____

WASHINGTON UNIFORM HEALTH CARE INFORMATION ACT ADDENDUM TO BUSINESS ASSOCIATE AGREEMENT

This Washington Uniform Health Care Information Act Addendum ("Washington Addendum") is incorporated into and made part of the Business Associate Agreement ("BAA") between Covered Entity and Business Associate. In the event of a conflict between this Washington Addendum and the BAA, this Washington Addendum shall control with respect to Health Care Information governed by Washington law.

PURPOSE

The parties acknowledge that Health Care Information maintained, used, or disclosed by Business Associate may be subject to both the Health Insurance Portability and Accountability Act of 1996, as amended ("HIPAA"), and Wash. Rev. Code ch. 70.02-~~(1991)~~ (the Washington Uniform Health Care Information Act ("UHCIA")).

The parties further acknowledge that Washington law may impose requirements that are more restrictive, more protective of individual privacy, or otherwise more stringent than HIPAA. Accordingly, this Washington Addendum establishes the parties' obligations with respect to Washington Health Care Information.

1. DEFINITIONS

Capitalized terms not otherwise defined herein shall have the meanings assigned in the BAA, HIPAA, or UHCIA, as applicable.

"Health Care Information" shall have the meaning set forth in Wash. Rev. Code §70.02.010.

"More Stringent Requirement(s)" means the legal requirement that affords greater protection to the individual, imposes a narrower disclosure authorization, creates additional procedural safeguards, grants greater rights of access, amendment, or control, or otherwise provides greater privacy or confidentiality protections.

2. GENERAL COMPLIANCE OBLIGATION

Business Associate shall comply with:

- (a) HIPAA (as defined in the BAA);
- (b) The UHCIA;
- (c) This Washington Addendum;
- (d) any Washington regulations implementing the UHCIA; and
- (e) any other applicable federal or Washington law governing the privacy, confidentiality, use, disclosure, retention, access, amendment, or security of Health Care Information.

3. HIERARCHY OF LAWS

Where both HIPAA and Washington law apply to a particular use, disclosure, request, authorization, revocation, subpoena, court order, access request, amendment request, or other handling of Health Care Information:

- (a) the parties shall comply with the More Stringent Requirement;
- (b) Business Associate shall not rely solely upon HIPAA where Washington law imposes additional conditions or restrictions; and
- (c) compliance with HIPAA shall not excuse noncompliance with Washington law.

4. WASHINGTON-SPECIFIC PRIVACY REQUIREMENTS

Business Associate shall implement policies and procedures reasonably designed to ensure compliance with Washington law requirements concerning:

- (a) patient authorization requirements;
- (b) disclosures without patient authorization;
- (c) revocation of authorizations;
- (d) third-party payor release of information;
- (e) limitations on redisclosure;
- (f) disclosure pursuant to subpoenas, discovery requests, and legal process;
- (g) disclosure to personal representatives and authorized representatives;
- (h) disclosures for forensic examinations;
- (i) release of information to protect the public;
- (j) patient access rights;
- (k) amendment or correction rights;
- (l) accounting and documentation obligations;
- (m) disclosure restrictions applicable to specially protected records; and
- (n) any Washington-law restrictions on secondary use or disclosure of Health Care Information.

5. SUBPOENAS, LITIGATION, AND LEGAL PROCESS

Business Associate shall not disclose Health Care Information in response to a subpoena, discovery request, administrative demand, investigative request, or other legal process unless:

- (a) such disclosure is expressly permitted under HIPAA and UHCIA; and
- (b) all notice, authorization, court order, protective order, or procedural requirements imposed by Washington law have been satisfied.

Where HIPAA would permit disclosure, but Washington law imposes additional More Stringent Requirements, Business Associate shall comply with the Washington requirements.

Pursuant to Wash. Rev. Code §70.02.170, individuals may have additional rights to civil remedies for violations of the UHCIA.

6. AUTHORIZATIONS

Business Associate shall not use or disclose Health Care Information pursuant to an authorization unless the authorization satisfies all applicable requirements of HIPAA and Washington law.

Where Washington law requires authorization language, content, duration, revocation rights, or procedural safeguards beyond those required by HIPAA, Business Associate shall ensure such requirements are met before relying on the authorization.

7. REDISCLOSURE

Business Associate shall implement reasonable safeguards to prevent unauthorized redisclosure of Health Care Information.

Where Washington law limits redisclosure more strictly than HIPAA, Business Associate shall comply with the Washington limitation. To the extent that a redisclosure is permitted under both HIPAA and Washington Law, Business Associate will verify the legal authority of any downstream recipient before sharing.

8. INDIVIDUAL RIGHTS

Business Associate shall cooperate with Covered Entity in responding to requests relating to:

- (a) access to records;
- (b) copies of records;
- (c) amendment or correction of records;
- (d) restrictions on disclosures;
- (e) revocation of authorizations; and
- (f) other rights granted under Washington law.

Where Washington law grants broader individual rights than HIPAA, Business Associate shall support Covered Entity's compliance with those rights. Likewise, where Washington law sets a shorter, more stringent timeline than HIPAA, Business Associate shall support Covered Entity's compliance with those shorter, more stringent timelines.

9. SPECIAL CATEGORIES OF INFORMATION

Business Associate acknowledges that certain information may be subject to additional Washington or federal confidentiality protections, including but not limited to:

- (a) behavioral health services/records;
- (b) mental health services/records;
- (c) adolescent behavioral health services/records;
- (d) substance use disorder services/records;
- (e) reproductive health information, services/records;
- (f) sexually transmitted diseases services/records;
- (g) HIV-related information, services/records;
- (h) genetic information, services/records; and
- (i) any other category receiving heightened protection under applicable law.

Business Associate shall comply with the More Stringent Requirements governing such information.

10. BREACH NOTIFICATION

To the extent that the Business Associate is required to provide Breach notification to Covered Entity, Business Associate recognizes the shorter timeframe for Covered Entity's compliance under Washington law, and agrees to provide notification to Covered Entity within no more than ten (10) business days following discovery (as defined in the BAA and HIPAA) of a Breach of Health Care Information.

11. SUBCONTRACTORS

Business Associate shall require each Subcontractor that creates, receives, maintains, accesses, transmits, or otherwise handles Health Care Information to agree in writing to comply with:

- (a) HIPAA (as defined in the BAA);
- (b) The UHCIA;
- (c) This Washington Addendum;
- (d) any Washington regulations implementing the UHCIA; and
- (e) any other applicable federal or Washington law governing the privacy, confidentiality, use, disclosure, retention, access, amendment, or security of Health Care Information.

12. TRAINING AND POLICIES

Business Associate shall maintain policies, procedures, and training reasonably designed to ensure compliance with Washington privacy requirements applicable to the services performed under the BAA.

13. CONFLICTS ANALYSIS

Washington state law governs to the extent it is more protective than HIPAA.

Upon Covered Entity's reasonable request, Business Associate shall cooperate in evaluating whether a Washington-law requirement is more stringent than a corresponding HIPAA requirement.

Business Associate shall document material determinations regarding conflicts between HIPAA and Washington law when such determinations affect operational practices or disclosure decisions.

14. SURVIVAL

The obligations of this Addendum shall survive termination of the BAA to the same extent as the confidentiality, privacy, security, return, destruction, and post-termination obligations contained in the BAA.